

2026 UPDATED EDITION

HIPAA Gap Assessment Checklist

For Dental Practices

Prepared by EdgeIQ Labs
compliance@edgeiqlabs.com
edgeiqlabs.com/compliance-shield

How to Use This Checklist

This checklist covers the key requirements of the **2026 HIPAA Security Rule update**. Use it to self-assess your practice's compliance posture or as a pre-audit preparation tool.

- ☐ ✅ **Compliant** — Fully implemented and documented
- ☐ ⚠️ **Partial** — Some gaps remain
- ☐ ❌ **Non-Compliant** — Not implemented or missing
- ☐ N/A — Not applicable to your practice

> **Disclaimer:** This checklist is an educational resource, not legal advice. HIPAA compliance requires ongoing assessment by qualified professionals. EdgeIQ Labs offers paid compliance services for practices needing expert guidance.

Section 1: Administrative Safeguards

1.1 Risk Analysis & Management

- ☐ Documented risk assessment completed within the last 12 months
- ☐ Risk assessment addresses all ePHI systems (EHR, imaging, email, cloud storage)
- ☐ Identified risks have documented mitigation plans with timelines
- ☐ Risk assessment updated after significant system changes or incidents
- ☐ Asset inventory includes all devices storing/transmitting ePHI

1.2 Security Personnel

- ☐ Designated HIPAA Privacy Officer (named individual)
- ☐ Designated HIPAA Security Officer (named individual)
- ☐ Both officers have current contact information on file
- ☐ Officers understand their responsibilities under 2026 rules

1.3 Workforce Training

- ☐ All staff completed initial HIPAA training before accessing ePHI
- ☐ Annual refresher training completed and documented for all staff
- ☐ Training covers 2026 Security Rule updates (MFA, breach notification)

- ☐ New hire training process documented and consistently followed
- ☐ Training records retained for minimum 6 years
- ☐ Sanctions policy for violations communicated to all staff

1.4 Contingency Planning

- ☐ Data backup plan documented and tested within last 12 months
- ☐ Disaster recovery plan exists and identifies critical systems
- ☐ Emergency mode operation plan documented
- ☐ Backup restoration tested successfully within last 12 months
- ☐ Off-site/cloud backup verified accessible

1.5 Business Associate Management

- ☐ Complete list of all vendors handling PHI maintained
- ☐ Signed BAA on file for every vendor touching PHI
- ☐ BAAs reviewed/updated within last 24 months
- ☐ Vendor security posture assessed before engagement
- ☐ Process for terminating BAAs when relationships end

Section 2: Physical Safeguards

2.1 Facility Access Controls

- ☐ Physical access to server rooms/ePHI storage restricted
- ☐ Visitor log maintained for sensitive areas
- ☐ Key/card access limited to authorized personnel
- ☐ Cameras or monitoring in place for high-security areas (if applicable)

2.2 Workstation Security

- ☐ Workstations positioned to prevent unauthorized viewing
- ☐ Auto-lock enabled on all workstations (max 15 min idle)
- ☐ Policy for securing portable devices (laptops, tablets)
- ☐ Screen privacy filters used where appropriate

2.3 Device & Media Controls

- ☐ Inventory of all devices containing ePHI maintained
- ☐ Secure disposal process for hard drives/media (certified destruction)
- ☐ Encryption enabled on all portable devices with ePHI
- ☐ USB/external media policy documented and enforced
- ☐ Bring-your-own-device (BYOD) policy if applicable

Section 3: Technical Safeguards

3.1 Access Controls ⭐ NEW 2026 REQUIREMENTS

- ☐ Unique user IDs for every staff member (NO shared logins)
- ☐ Role-based access controls implemented (minimum necessary)
- ☐ **Multi-factor authentication (MFA) enabled on ALL systems with ePHI**
- ☐ MFA covers remote access, VPN, EHR, email, and cloud services
- ☐ Password complexity policy enforced (min 12 chars, no reuse)
- ☐ Account lockout after failed attempts configured
- ☐ Privileged access reviewed quarterly
- ☐ Access terminated immediately upon employee departure

3.2 Audit Controls

- ☐ Logging enabled on all systems containing ePHI
- ☐ Logs capture: user ID, action, timestamp, data accessed
- ☐ Log retention meets minimum 6-year requirement
- ☐ Regular log review process documented and performed
- ☐ Automated alerts for suspicious access patterns

3.3 Integrity Controls

- ☐ Mechanisms to detect unauthorized alteration of ePHI
- ☐ Digital signatures or checksums where appropriate
- ☐ Change tracking enabled in EHR system

3.4 Transmission Security

- ☐ Encryption in transit for all ePHI (TLS 1.2+ minimum)
- ☐ Email encryption for patient communications
- ☐ Secure file transfer methods documented
- ☐ No ePHI transmitted via unencrypted channels (SMS, personal email)

3.5 Authentication

- ☐ Strong authentication for remote access

- ☐ Session timeout configured appropriately
- ☐ Certificate-based auth where feasible

Section 4: Breach Notification ⭐ UPDATED 2026

4.1 Incident Response Plan

- ☐ Written breach response plan exists and is accessible
- ☐ Plan updated for **72-hour notification window** (was 60 days)
- ☐ Breach assessment team identified with roles defined
- ☐ Contact list for OCR, state AG, affected individuals current
- ☐ Breach notification templates pre-drafted
- ☐ At least two staff trained on breach response procedures

4.2 Breach Drills

- ☐ Tabletop breach exercise conducted within last 12 months
- ☐ Drill results documented with lessons learned
- ☐ Plan updated based on drill findings

Section 5: Policies & Documentation

5.1 Required Policies

- ☐ Notice of Privacy Practices (NPP) updated for 2026 changes
- ☐ NPP distributed to patients at first point of contact
- ☐ Patient acknowledgment of NPP obtained and filed
- ☐ Minimum Necessary Standard policy documented
- ☐ Right of Access policy (30-day response requirement)
- ☐ Sanctions policy for HIPAA violations
- ☐ Complaint procedure documented and accessible
- ☐ Record retention/destruction schedule documented

5.2 Documentation Retention

- ☐ All policies dated and version-controlled
- ☐ Documentation retained for minimum 6 years
- ☐ Staff sign-offs on policies collected annually
- ☐ Previous versions archived (not deleted)

Section 6: Patient Rights

6.1 Right of Access

- ☐ Process for patient record requests documented
- ☐ Response within 30 calendar days (no extensions without cause)
- ☐ Fees for copies comply with state/federal limits
- ☐ Electronic copies provided in requested format when feasible
- ☐ Tracking system for request receipt and fulfillment dates

6.2 Amendments & Restrictions

- ☐ Process for patient amendment requests documented
- ☐ Restriction request handling policy in place
- ☐ Accounting of disclosures available upon request

Scoring Guide

Score Range	Status	Recommended Action
85–100%	✅ Audit Ready	Maintain with quarterly reviews
70–84%	⚠️ Moderate Risk	Address gaps within 90 days
50–69%	❌ High Risk	Immediate remediation needed
Below 50%	🚨 Critical	Engage compliance professional immediately

Next Steps

1. **Self-Assessment Complete?** Reply to this email for a free review of your findings — entirely over email, no calls needed.
2. **Gaps Identified?** Our Starter plan ($299/mo) includes policy templates and monthly scans to close them.
3. **Audit Incoming?** Professional plan ($499/mo) includes audit representation and breach response support.

EdgeIQ Labs Compliance

compliance@edgeiqlabs.com | edgeiqlabs.com/compliance-shield

© 2026 EdgeIQ Labs. This checklist is provided for educational purposes. Consult qualified legal counsel for compliance decisions.